NEP Haryana Excellence Awards 2026: VM / Server Requirements Assessment

Prepared	2026-10-18
Repository state inspected	branch `fix/nep2026-scoring-repair`, HEAD `892df20` (first assessment). Re-checked on HEAD `affe59d` after gaps G1–G6 were fixed; see §9 and §11.
Purpose	Technical basis for requesting VM/server capacity from the state IT infrastructure / data-centre team
Companion	`VM_SERVER_REQUIREMENTS_EMAIL.md` is the email to send

This document separates three kinds of statement:

- **[VERIFIED]**: read directly from the code or configuration, or produced by a command run on 2026-10-18 (see §11).
- **[ESTIMATE]**: a provisional infrastructure recommendation. No load data, user counts or storage-growth figures exist in the repository, so every estimate is a starting point that must be confirmed by load testing.
- **[GAP]**: a missing configuration, dependency or decision that blocks or weakens a VM deployment.

---

1. Summary

The application is a two-tier web system: a static React single-page app and a Django REST API, with PostgreSQL as the system of record and evidence documents stored on the local filesystem of the API server.

Recommended starting footprint **[ESTIMATE]**: **two production VMs** (one application/web VM and one PostgreSQL VM), **one staging VM**, and **separate backup storage**. Ubuntu Server 24.04 LTS on all of them.

The first assessment found code gaps G1–G8 (§9). **G1–G6 are now fixed.** G7 (legacy Cloudinary path) and G8 (VM deploy job) remain open. Production now **requires** `REDIS_URL`. Production should also set `MEDIA_ROOT` **or** `EVIDENCE_STORAGE_VAULT` to the persistent evidence volume; `check --deploy` warns (`evidence.W001`) while the vault is still inside the code directory.

The application has never been deployed; this would be its first production environment. The repository contains a CI/CD workflow written for Azure App Service (`nep-excellence`), but it is not in use. Hosting on the requested VMs needs a VM deployment job (G8), which this assessment does not create.

---

2. Architecture discovered [VERIFIED]

```
Browser ──HTTPS──▶  Reverse proxy (TLS)  ──▶  Static SPA files (Frontend/NEP_HARYANA_INT/dist)
                          │
                          └── /api/* ──▶ Gunicorn (Django 6.0 WSGI, config.wsgi)
                                                  │
                                                  ├──▶ PostgreSQL (DATABASE_URL, required in production)
                                                  ├──▶ Local filesystem: MEDIA_ROOT/evidence_vault (evidence)
                                                  ├──▶ Cache: Redis if REDIS_URL is set, otherwise per-process memory
                                                  └──▶ SMTP relay (verification, invitations, password reset)
```

2.1 Frontend

Item	Finding	Source
Framework	React 19, React Router 7, Vite 8, Tailwind 3, Recharts, Framer Motion	`Frontend/NEP_HARYANA_INT/package.json`
Build output	Static files in `dist/`. About **2.7 MB**, 3 files scanned by the bundle checker. Vite warns about a chunk over 500 kB (performance only, not a blocker).	scratch build, §11
Hosting needs	Any static web server with an SPA fallback (all unknown paths → `index.html`). `vercel.json` contains exactly this rewrite. No server-side rendering and no Node runtime on the server.	`vercel.json`, `App.jsx` routes
Build-time config	`VITE_API_BASE_URL`, needed only if the API is on another origin. Since the G6 fix, production builds otherwise call same-origin `/api`; before it they called `http://<page-host>:8000/api`.	`src/api/auth.js`
Build toolchain	Node 24 (CI). Needed on the build runner only, not on the production VM.	workflow `frontend-checks`

2.2 Backend

Item	Finding	Source
Framework	Django 6.0.5, Django REST Framework 3.17.1, custom JWT auth (PyJWT), django-cors-headers, WhiteNoise	`Backend/requirements.txt`, `config/settings/base.py`
Runtime	Python 3.12 in CI (Django 6.0 requires Python ≥ 3.12). The local dev venv is 3.13.7.	workflow, venv
App server	Gunicorn 26 is a dependency. WSGI entry point is `config.wsgi:application`, whose default is `config.settings.production`. There is no ASGI/WebSocket usage.	`config/wsgi.py`
Apps	authentication, admin_panel, nominations, scoring, evidence, university, college, reports, forms	`Backend/apps/`
Background workers / scheduler	**None.** There is no Celery, RQ, cron or scheduled task in the code. All work, including email sending and score refresh, runs synchronously inside the request.	code search
Management commands (one-off)	`provision_head_admin` (reads `HEAD_ADMIN_PASSWORD` or prompts), `import_haryana_institutions` (DHE registry of 1,152 institutions) followed by `import_aishe_registry` (AISHE master list of 1,683 Haryana institutions), both from `Backend/data/aishe_import/`, `export_nep_schema` (dev). `create_dev_users` and `seed_demo_submissions` are **demo only and must not run in production**.	`apps/*/management/commands`
Reports	CSV export generated in-request	`apps/reports/views.py:156`
Throttling	DRF: anon 120/min, user 240/min. Login lockout after repeated failures (15 minutes), plus resend cooldowns. All of these are stored in the Django cache.	`base.py`, `authentication/views.py`

2.3 Database [VERIFIED]

- `config/settings/production.py` **refuses to start** unless `DATABASE_URL` is a PostgreSQL (or PostGIS) URL. SQLite is refused (FIN-07). Connections use `conn_max_age=600` with health checks.
- Driver: `psycopg2-binary` 2.9.12.
- Django 6.0 supports PostgreSQL 14 and later. **Recommend PostgreSQL 16.**

- The development SQLite file is 2.2 MB with demo data. This indicates the structured data is small; most of the storage is evidence files.

2.4 Evidence / file storage [VERIFIED]

- Backend: `apps.evidence.storage.FileSystemEvidenceStorage`. It writes atomically (temporary file, then rename), confines paths to the vault, and keeps a `quarantine/` subfolder.
- Location: `MEDIA_ROOT / 'evidence_vault'`, where `MEDIA_ROOT = BASE_DIR / 'media'`, which is `<deploy-dir>/Backend/media/` by default. Since the G2 fix, `MEDIA_ROOT` and `EVIDENCE_STORAGE_VAULT` can be set from the environment and **must point at the persistent volume on a VM**.
- Limits: PDFs **5 MB** (`MAX_PDF_FILE_SIZE`); other formats **25 MB** (`MAX_EVIDENCE_FILE_SIZE`). Both can be set from the environment, and the browser enforces the same limits (`src/utils/fileValidators.js`). Allowed formats are pdf, png, jpg, jpeg, webp, docx and xlsx, checked by magic bytes; PDFs are also structurally parsed with `pypdf`.
- Delivery: evidence is served **only through authenticated API views**, which read the whole file into memory (`HttpResponse(content_bytes)`). `/media/` is mounted only when `DEBUG=True`, so the reverse proxy must **not** expose the media directory.
- Upload handling: files over Django's 2.5 MB in-memory threshold spool to the OS temp directory, so the VM needs free `/tmp` space.
- A legacy nomination screen (`NominationWorkspace.jsx:458`) uploads files **directly from the browser to Cloudinary**, a third-party SaaS. The backend supplies the Cloudinary settings from `CLOUDINARY_*` variables, and the code falls back to hard-coded defaults if they are unset. **[GAP]** A decision is needed on whether this path stays in production (§10, question Q5).
- There is no antivirus scanning, and none is configured.

2.5 Supporting services

Service	Required?	Finding
Redis	**Yes, for a multi-worker deployment**	When `REDIS_URL` is set, `base.py` switches the cache to `django.core.cache.backends.redis.RedisCache`. Otherwise every Gunicorn worker keeps its own lockout, cooldown and throttle counters, which weakens brute-force protection. Since the G3 fix, the `redis` package is pinned and `production.py` refuses to start without `REDIS_URL`.
SMTP	**Yes**	Used for email verification on signup, invitations/activation and password reset. `production.py` refuses the console and locmem backends. If delivery fails, signup returns HTTP 503 and the transaction is rolled back, so the application never claims a mail was sent when it was not. Variables: `EMAIL_BACKEND`, `EMAIL_HOST` (code default `smtp.gmail.com`), `EMAIL_PORT` (587), `EMAIL_USE_TLS`, `EMAIL_USE_SSL`, `EMAIL_HOST_USER`, `EMAIL_HOST_PASSWORD`, `DEFAULT_FROM_EMAIL`. Links are built from **`FRONTEND_URL`**.
SMS gateway	**Not used by the current signup flow**	The frontend no longer calls the OTP endpoints. The backend OTP routes still exist but fail closed with `DisabledSMSBackend`. Confirm with HSHEC that no SMS is required (Q6).
Celery / message broker	No	Not present in the code.
Object storage (S3/Blob)	No	Not present in the code; storage is the local filesystem. The storage class is pluggable for future use.

3. Recommended server specifications [ESTIMATE]

> **Superseded on 2026-10-21.** HSHEC has given the expected load (at most 150 applications, 250–300 concurrent users). The sizing in §3–§4 below was made without that data. The revised sizing is **one production VM (4 vCPU / 8 GB / 60 GB + 100 GB evidence), staging 2 vCPU / 4 GB / 60 GB, and 250 GB backup**. See

> VM_SIZING_CALCULATIONS.md for the calculations. **Updated 2026-10-22:** daily evidence backups, recovery targets, a production load test and the outbound Cloudinary rule were added. See `SERVER_REQUIREMENTS_SUMMARY.md` §4, §6, §8 and §9.

Assumptions (none of these figures come from the codebase):

- The user population is the Haryana higher-education institutions in the bundled DHE registry (**1,152 institutions**, **[VERIFIED]** from the import command), plus state administrators and review committees.
- No concurrent-user, traffic or upload-volume figures are available. The sizes below are a conservative starting configuration for a government portal with deadline-driven peaks. They **must be validated by a load test** (§7) before the submission window opens.
- One application VM, so that local-disk evidence storage stays consistent (see §7 on scaling).

3.1 VM table

#	Role	Environment	OS	vCPU	RAM	Disk	Notes
1	**Application / web**: Nginx (TLS, static SPA), Gunicorn + Django, Redis (localhost only)	Production	Ubuntu Server 24.04 LTS (64-bit)	**4**	**8 GB**	**60 GB** SSD OS/app volume + **250 GB** SSD **separate, expandable data volume** for evidence	Gunicorn starts at 2×vCPU+1 = 9 workers. Each upload or download can hold up to ~25 MB in memory, which is why the RAM figure is 8 GB rather than 4 GB.
2	**Database**: PostgreSQL 16	Production	Ubuntu Server 24.04 LTS	**4**	**8 GB**	**40 GB** OS + **100 GB** SSD data/WAL volume	Private network only. WAL archiving for point-in-time recovery. A managed PostgreSQL service in the data centre is an acceptable alternative.
3	**Staging** (all-in-one: Nginx, Gunicorn, Redis, PostgreSQL)	Staging / UAT	Ubuntu Server 24.04 LTS	**2**	**4 GB** (8 GB preferred)	**100 GB** SSD	Migration rehearsal, SMTP test, restore drills and load tests. It must use separate credentials and a separate database.
4	**Backup storage** (NAS/NFS, object store or backup vault)	Shared	n/a	n/a	n/a	**≥ 1 TB** to start; see §4	It must sit outside the production VMs, preferably in a separate location or zone.

Fallback if only one production VM can be allocated: 8 vCPU, 16 GB RAM, with separate OS, PostgreSQL and evidence volumes. This works, but the database and application then share resources and fail together, and backups must still go off the VM.

3.2 Software stack (to be installed by the deployment team)

Component	Version	Source
Python	3.12 (Ubuntu 24.04's system Python) with `venv`	matches CI
Python packages	`Backend/requirements.txt` (includes `pypdf` and `redis` since the G1/G3 fixes)	
Gunicorn	26.0.0 (from requirements), run under systemd	
Nginx	distribution package	reverse proxy, TLS, static files
PostgreSQL	16 (14 at minimum)	Django 6.0 support matrix
Redis	7.x (distribution package), bound to 127.0.0.1, with a password	
PostgreSQL client tools	same major version as the server	`pg_dump` for backups
Certbot, or the state CA's certificate tooling		TLS
Node.js	**not required on the server** (the frontend is built in CI)	

---

4. Storage and backup sizing [ESTIMATE]

The codebase has no data on how many evidence files institutions upload or how large they are. Use this formula and recalculate once HSHEC confirms the figures (Q2):

> Evidence storage ≈ institutions × files per submission × average file size × (1 + headroom for re-uploads and quarantine)

Illustration only, not a forecast: 1,152 × 40 files × 4 MB × 1.25 ≈ **230 GB** for one award cycle. The **hard ceiling per file is 25 MB**. The 250 GB evidence volume is therefore a starting size on an **expandable volume (LVM or cloud volume)**, with an alert at 70% used.

Item	Starting allocation	Basis
Evidence volume (production)	250 GB, expandable	formula above
PostgreSQL data	100 GB	Structured data is small (the dev DB is 2.2 MB); the allocation leaves room for WAL, indexes and growth
Backup capacity	≥ 1 TB to start (about 3× primary data)	Daily DB dumps + WAL for 35 days + evidence snapshots for the retention period
Retention	**To be confirmed** (Q8)	The existing ops checklist proposes daily backups, 35-day point-in-time recovery and long-term archival. Statutory retention is a policy decision, not a code fact.

Backups must cover two things together: the PostgreSQL database **and** the evidence volume. The database stores storage keys that point to files on the volume, so a restore needs consistent copies of both.

---

5. Network, ports, DNS and TLS

5.1 Ports [VERIFIED requirements, ESTIMATE for the rule set]

Direction	From → To	Port / protocol	Purpose
Inbound	Internet → App VM	**443/TCP (HTTPS)**	Application and API
Inbound	Internet → App VM	80/TCP	Redirect to HTTPS only (plus ACME validation if Let's Encrypt is used)
Inbound	Admin network / VPN / bastion → all VMs	22/TCP (SSH, keys only)	Administration; **not open to the internet**
Internal	App VM → DB VM	5432/TCP	PostgreSQL; only the App VM may connect
Local	App VM localhost	6379/TCP, 8000/TCP (or a Unix socket)	Redis and Gunicorn; **never exposed**
Outbound	App VM → SMTP relay	**587/TCP (STARTTLS)** or 465/TCP	Verification, invitation and reset mail
Outbound	All VMs → OS/package mirrors	443/TCP	Security updates, pip/apt (a proxy or mirror is acceptable)
Outbound	All VMs → NTP	123/UDP	Clock sync (JWT expiry and token TTLs depend on it)
Outbound	All VMs → backup target	per backup product	Backups
Outbound	CI runner → App VM	22/TCP or an agreed deploy channel	Deployment (to be designed; see §8)

5.2 Reverse proxy requirements [VERIFIED from code]

- `client_max_body_size` **30M** (25 MB file plus multipart overhead). If the limit is lower, uploads fail before they reach Django.
- Set `X-Forwarded-Proto` and configure `SECURE_PROXY_SSL_HEADER=true`. Without these, `SECURE_SSL_REDIRECT` loops behind the proxy.
- **Overwrite** `X-Forwarded-For` with the client address (`proxy_set_header X-Forwarded-For $remote_addr;`). With `TRUSTED_PROXY_COUNT=1`, which is the production default, Django uses only the last address in that header for throttling, login lockout and audit logs, so it must be the one Nginx added.
- Serve `dist/` with the SPA fallback, proxy `/api/` to Gunicorn, and do **not** serve `Backend/media/`.
- Proxy read timeout of 60–120 s for large uploads and the CSV export.
- **Security headers for the static site.** Django sets headers only on `/api/` responses. On 2026-10-21 the policy below was tested against the production build in headless Chrome (home, login, sign-up, OTP and dashboard pages) and caused no violations. Check the evidence preview on staging, because it loads `blob:` frames. If the legacy Cloudinary upload is ever enabled (Q5), add `https://api.cloudinary.com` to `connect-src`.

```
nginx add_header Content-Security-Policy "default-src 'self'; script-src 'self'; style-src 'self' 'unsafe-inline' https://fonts.googleapis.com; font-src 'self' https://fonts.gstatic.com; img-src 'self' data: blob:; frame-src 'self' blob:; connect-src 'self'; object-src 'none'; base-uri 'self'; form-action 'self'; frame-ancestors 'none'" always; add_header X-Frame-Options "DENY" always; add_header X-Content-Type-Options "nosniff" always; add_header Referrer-Policy "strict-origin-when-cross-origin" always; add_header Permissions-Policy "camera=(), microphone=(), geolocation=()" always;
```

5.3 DNS and certificates

- One FQDN, for example `<app-subdomain>.haryana.gov.in`, serving both the SPA and `/api/` (same origin). With one origin, CORS is not needed and `FRONTEND_URL`, `ALLOWED_HOSTS` and `VITE_API_BASE_URL` all use one value.

- A TLS certificate for that FQDN from a CA trusted by browsers (the state/NIC CA, a commercial CA, or Let's Encrypt if policy permits), with a renewal procedure.
- HSTS is on by default (30 days). `SECURE_HSTS_INCLUDE_SUBDOMAINS` and preload are **off**; Django's deploy check reports warnings W005 and W021 for this. Enable them only if the parent domain policy allows.
- **Email DNS:** SPF, DKIM and DMARC for the sender domain used in `DEFAULT_FROM_EMAIL`. Without them, verification emails are likely to land in spam.

5.4 Bandwidth

There is no traffic data, so a figure cannot be derived. The largest single transfer is a 25 MB evidence file. Start with **≥ 100 Mbps** shared uplink and review it after the load test. At 100 Mbps, a 25 MB upload takes about 2 s of line time.

---

6. Environment variables and secrets

Store these in a root-owned `EnvironmentFile` (mode 0600) for the systemd unit, or in the data centre's secret store. **Never commit them.** `base.py` also loads `Backend/.env` if it exists, but since 2026-10-21 it only fills in variables the real environment does not set. If a `.env` file is used, it needs the same 0600 permissions.

Variable	Secret?	Required	Notes
`DJANGO_SETTINGS_MODULE=config.settings.production`	no	**yes**	`manage.py` **defaults to development settings.** Every `migrate` or management command on the VM must run with this variable set.
`DJANGO_SECRET_KEY`	**yes**	yes	Random, ≥ 50 characters. The committed development key is refused.
`JWT_SIGNING_KEY`	**yes**	recommended	≥ 50 characters. Falls back to `DJANGO_SECRET_KEY` if unset.
`JWT_PREVIOUS_SIGNING_KEYS`	**yes**	for key rotation	comma-separated
`DATABASE_URL`	**yes**	yes	`postgres://<user>:<password>@<db-host>:5432/<db>`; add `?sslmode=require` if the DB enforces TLS
`REDIS_URL`	**yes**	**yes**: production refuses to start without it	`redis://:<password>@127.0.0.1:6379/0` (`rediss://` and `unix://` are also accepted)
`MEDIA_ROOT` / `EVIDENCE_STORAGE_VAULT`	no	**yes on a VM**	Path on the persistent evidence volume, e.g. `/srv/nep/media`. The vault defaults to `$MEDIA_ROOT/evidence_vault`.
`STATIC_ROOT`	no	optional	`collectstatic` target; default `Backend/staticfiles`
`LOG_LEVEL`	no	optional	default `INFO`; logs go to stderr
`ALLOWED_HOSTS`	no	yes	production FQDN. Startup fails if empty.
`FRONTEND_URL`	no	yes	`https://<fqdn>`, used in all email links
`CORS_ALLOWED_ORIGINS`	no	only if the SPA is on a different origin	
`EMAIL_BACKEND`, `EMAIL_HOST`, `EMAIL_PORT`, `EMAIL_USE_TLS`, `EMAIL_USE_SSL`, `EMAIL_HOST_USER`, `DEFAULT_FROM_EMAIL`	no	yes	the code default host is `smtp.gmail.com`, which must be overridden with the approved relay
`EMAIL_HOST_PASSWORD`	**yes**	yes	
`SECURE_PROXY_SSL_HEADER=true`	no	yes behind Nginx	
`TRUSTED_PROXY_COUNT`	no	optional	Number of proxies that append to `X-Forwarded-For`. Production default **1** (Nginx); development default 0 (header ignored).
`LOGIN_LOCKOUT_ATTEMPTS`, `LOGIN_ACCOUNT_LOCKOUT_ATTEMPTS`, `LOGIN_LOCKOUT_MINUTES`	no	optional	5 failures per account and address, 50 per account from all addresses, 15-minute lock

Variable	Secret?	Required	Notes
`SECURE_SSL_REDIRECT`, `SECURE_HSTS_SECONDS`, `SECURE_HSTS_INCLUDE_SUBDOMAINS`	no	optional	defaults: True / 30 days / False
`MAX_PDF_FILE_SIZE`	no	optional	default 5242880 (5 MB)
`MAX_EVIDENCE_FILE_SIZE`	no	optional	default 26214400 (25 MB) for non-PDF formats; keep it consistent with the Nginx limit and with `src/utils/fileValidators.js`
`JWT_ACCESS_TOKEN_MINUTES`, `JWT_REFRESH_TOKEN_DAYS`, `PASSWORD_RESET_TIMEOUT`	no	optional	15 min / 7 days / 24 h
`SMS_BACKEND`, `OTP_*`	(provider credentials would be)	no, unless SMS is re-enabled	
`CLOUDINARY_CLOUD_NAME`, `CLOUDINARY_UPLOAD_PRESET_NAME`	no	only if the legacy path is kept (Q5)	No default since 2026-10-21: while unset, the legacy upload screen reports that uploads are not configured
`HEAD_ADMIN_PASSWORD`	**yes**	one-off	Used only by `provision_head_admin`. Remove it after provisioning.
`VITE_API_BASE_URL`	no	build time, only if the API is on another origin	Without it, production builds call same-origin `/api`

7. Logging, monitoring, security and scalability

Logging. Since the G5 fix, `production.py` sends application and Django logs to stderr at `LOG_LEVEL` (default INFO). Recommended setup: capture Gunicorn and Django stderr in journald, rotate the Nginx access and error logs, and forward to the state SIEM or log platform if one exists. Retention period: Q9.

Monitoring [ESTIMATE]. Alert on host CPU, RAM and disk, with **evidence volume ≥ 70%** as a specific alert. Also monitor the HTTP 5xx rate, an uptime probe on `https://<fqdn>/`, PostgreSQL availability and replication/backup job status, Redis availability, certificate expiry, and the SMTP failure rate (signup returning 503).

Security baseline [ESTIMATE]. - Host: CIS-style hardening, SSH keys only with no root login, automatic security updates, a host firewall (ufw/nftables) matching §5.1, and fail2ban on SSH. - Services run as an unprivileged account. The evidence directory is owned by that account (mode 0750) and is not reachable through Nginx. - PostgreSQL: listen only on the private interface, use a least-privilege application role, and enforce TLS where supported. - Do **not** create Django superusers or demo accounts in production. Do not run `create_dev_users` or `seed_demo_submissions`. Bootstrap the first administrator with `provision_head_admin`. - Optional: antivirus scanning (ClamAV) of the evidence volume (Q10).

Scalability [ESTIMATE]. - Vertical scaling (more vCPU/RAM, more Gunicorn workers) is the first step and needs no code change. - **Horizontal scaling (two or more application VMs) is not possible without a code change or shared storage.** Evidence is on local disk, so additional app VMs need either a shared POSIX volume (NFS) mounted at the evidence path, or an object-storage backend implementing `BaseEvidenceStorage`. They would also need a shared Redis on its own host. - PostgreSQL can be scaled up independently on its own VM. - **Load test** before the submission window opens (150-user trial on staging, then the full test on the production VM; see `VM_SIZING_CALCULATIONS.md` §10): login, the assessment save/submit flow, 25 MB uploads and evidence downloads, at a concurrency HSHEC agrees represents the deadline peak (Q1).

8. CI/CD and release gate

[VERIFIED] `.github/workflows/master_nep-excellence.yml`:

- **Release gate:** on push to `master` (with checks only on pull requests), it runs migration completeness, `check --deploy` under production settings, the backend test suite, frontend tests, the lint gate, the production build and the bundle credential scan. Deployment runs only if all of them pass.
- **Deploy target (written, never used):** Azure App Service `nep-excellence` through OIDC (`azure/login`, `azure/webapps-deploy`). Only `Backend/` is packaged; `db.sqlite3` and `media/` are excluded. **The built frontend is not deployed by this workflow.**
- **[GAP] For a VM:** a new deploy job is needed. It should: 1. reuse the same gate; 2. ship the backend and the built `dist/` (set `VITE_API_BASE_URL` only if the API is on another origin); 3. install requirements into a venv; 4. run `migrate` under `config.settings.production`; 5. run `collectstatic`; 6. restart the systemd units; 7. **never overwrite the evidence directory.**

A manual approval (`environment: production`) is advised. This document does not change the workflow. - A green GitHub Actions run of this workflow on the release commit has **not been observed** in this assessment.

---

9. Gaps that need code or configuration changes before a VM go-live

G1–G6 were fixed on 2026-10-18 on top of `affe59d`. Each fix has a regression test.

ID	Gap	Status / fix
G1	`pypdf` was imported by `apps/evidence/validators.py` but missing from `Backend/requirements.txt`, so a server built from that file rejected valid PDFs. **Also:** commit `affe59d` (streaming uploads) passed only the first 8 KB of a streamed upload to the PDF structure check, so every valid PDF over 8 KB on a PDF-only criterion was rejected (missing `%%EOF`).	**FIXED.** `pypdf==6.19.0` was added to `Backend/requirements.txt`. `pipeline.py` now validates the whole streamed file for PDF-only criteria. Test: `test_streamed_pdf_larger_than_header_chunk_is_validated_in_full`, which fails on `affe59d` and passes after the fix.
G2	The evidence path was hard-coded under the code directory	**FIXED.** `MEDIA_ROOT` and `EVIDENCE_STORAGE_VAULT` can be set from the environment (same defaults). A new deploy check, `evidence.W001`, warns while the vault is inside `BASE_DIR`. Tests: `ProductionDeploymentConfigTests`, `EvidenceVaultDeployCheckTests`.
G3	The `redis` package was missing, and `REDIS_URL` was optional (FIN-11). This became more important with `affe59d`'s 60 s JWT user cache: with per-worker memory caches, a logout, password reset or session revocation clears only one worker's copy.	**FIXED.** `redis==6.4.0` was added. `production.py` refuses to start unless `REDIS_URL` is `redis://`, `rediss://` or `unix://`. The CI deploy-check step now passes a placeholder `REDIS_URL`. The first production environment must provide Redis (VM 1).
G4	No `STATIC_ROOT` (FIN-18)	**FIXED.** `STATIC_ROOT` defaults to `Backend/staticfiles` (git-ignored) and can be overridden from the environment. `collectstatic` copies 157 files.
G5	No `LOGGING`; localhost CORS entries active in production (FIN-18)	**FIXED** in `production.py`. Logs go to stderr at `LOG_LEVEL` (default INFO). Localhost and 127.0.0.1 origins are removed and the CORS regexes are emptied.
G6	The SPA fell back to `http://<host>:8000/api`	**FIXED.** Production builds fall back to same-origin `/api`; the `:8000` fallback applies to `npm run dev` only. `checker.js` and `reports.js` now import the one `API_BASE_URL` from `auth.js`. Test: `tests/test_deployment_config.mjs`.
G7	Legacy Cloudinary browser upload path, with hard-coded defaults. Evidence uploaded this way leaves state infrastructure (a data-residency question).	**OPEN**: decide (Q5), then remove the path or configure an approved account
G8	No VM deployment workflow	**OPEN**: see §8

Other observations from reviewing commits `f86b75e`..`affe59d` (not changed): - `base.py` now calls `load_dotenv(..., override=True)`, so a `Backend/.env` file **overrides** real environment variables, including systemd or App Service secrets. On a server, make sure no `.env` file is present, or drop `override=True`. - The JWT user cache (60 s) is cleared by `revoke_sessions()`, logout and password reset. Approving an institution request (`admin_panel/services.py`, around line 1446) changes the user's binding without clearing it, so the user may see the pre-approval state for up to 60 s. This is restrictive, not permissive. - With Redis, cached `User` objects (including the password hash) are stored in Redis. Keep Redis local-only and password-protected (§5.1).

Other items from earlier audits that are still open and are not infrastructure: FIN-03 (University certification held pending a council decision on U6/U18.3), FIN-09/10 (policy), FIN-13/14 (input validation), FIN-16 (mock settings page) and FIN-17 (npm advisories; `pip-audit` not run). See `haryana/docs/audits/NEP_PRODUCTION_REMEDIATION_RESULTS.md`.

---

10. Questions for HSHEC / data centre

#	Question	Why it matters
Q1	Expected number of active users and the peak concurrency in the final days before the submission deadline?	Gunicorn worker count, VM size, load-test target
Q2	Expected evidence files per institution and typical size? Will there be more than one award cycle on the same deployment?	Evidence volume and backup sizing
Q3	Which data centre or cloud (e.g. HARTRON / NIC / SDC), and which OS images are permitted? Is Ubuntu 24.04 LTS acceptable, or is RHEL/Rocky 9 mandated?	Base image
Q4	Can the data centre provide managed PostgreSQL, managed backups and a load balancer / WAF?	Could replace VM #2 and the self-managed backups
Q5	Should the legacy Cloudinary upload path remain? Is third-party storage of any evidence permitted?	Data residency, outbound policy
Q6	Confirm that no SMS/OTP channel is required. If one is, which DLT-registered provider?	SMS integration
Q7	Which SMTP relay and sender address (government mail relay or approved transactional provider)? Who manages SPF, DKIM and DMARC for the sender domain?	Email verification will not work without them
Q8	Required backup retention and recovery objectives (RPO/RTO)? Is an off-site copy required?	Backup capacity and design
Q9	Log retention period, and is there a SIEM or log platform to forward to?	Logging design
Q10	Is antivirus scanning of uploaded files mandated?	Optional ClamAV
Q11	Production FQDN and certificate authority. Who renews the certificate?	DNS, TLS
Q12	How will deployments reach the VM (SSH from CI, a pull-based agent, or a manual window)? Is a VPN or bastion required?	CI/CD design
Q13	Is a security audit (for example a CERT-In empanelled auditor's report) required before go-live?	Timeline

---

11. Checks performed (2026-10-18)

All checks were read-only with respect to the repository. Outputs went to the session scratch directory. `git status --porcelain` showed **0** entries before and after.

#	Check	Command (summary)	Result
1	Migration completeness	`manage.py makemigrations --check --dry-run --settings=config.settings.ci`	**No changes detected**
2	Django deployment checklist	`manage.py check --deploy --fail-level ERROR`, with production settings and CI-style placeholder env values (as in the workflow)	**Pass**: 0 errors, 2 warnings (W005 HSTS subdomains, W021 HSTS preload)
3	Static collection	`manage.py collectstatic --dry-run --noinput`, same env	**Fails**: `ImproperlyConfigured`, `STATIC_ROOT` not set (G4)
4	Backend test suite	`manage.py test apps` with an isolated scratch settings module (based on `config.settings.ci`; `BASE_DIR`, `MEDIA_ROOT`, the vault and the DB redirected to scratch)	**877 tests, OK**. Run with the local venv, which includes `pypdf`, so it does not reproduce the CI dependency set.
5	Frontend tests	`npm test`	**109/109 pass**
6	Frontend lint gate, build, bundle scan	`npm run lint:gate`; `vite build --outDir <scratch>`; `check-bundle-secrets.mjs <scratch>`	Lint gate **OK** (283 non-blocking lint errors remain). Build **OK** (2.7 MB, chunk-size warning). Bundle scan **OK** (3 files, no development credentials).
7	PDF validation without `pypdf`	In-process probe: a valid 1-page PDF through `ContentValidator.validate_pdf_structure`, with and without `pypdf` importable	With pypdf: **accepted**. Without it: **`MalformedFileError`** (G1).
8	Dependency inspection	`pip show` on the declared packages in the local venv	`pypdf` is required by none of them; `redis` is not installed

Re-run after the G1–G6 fixes (HEAD `affe59d` plus working-tree changes):

Check	Result
Backend suite on `affe59d` before the fixes (baseline)	905 tests OK
Backend suite after the fixes (scratch settings)	**913 tests OK** (8 new)
New PDF regression test against the `affe59d` pipeline	**Fails** with `MalformedFileError: … missing terminal '%%EOF'`; passes with the fix
`makemigrations --check --dry-run`	No changes detected
`check --deploy` with the CI env but no `REDIS_URL`	Refuses to start (`ImproperlyConfigured: REDIS_URL must …`)
`check --deploy` with the CI env plus `REDIS_URL`	0 errors; warnings W005, W021 and `evidence.W001` (the vault is in the code directory)
Same, with `MEDIA_ROOT` outside the code directory	0 errors; W005 and W021 only
`collectstatic` (to a scratch `STATIC_ROOT`)	157 files copied
`RedisCache` with pinned `redis==6.4.0` (wheel on the path, no connection)	Backend loads
`npm test`	**111/111 pass** (2 new)
`npm run lint:gate`	OK (285 non-blocking)
Production build plus bundle scan	OK. The bundle's API base is `/api`, with 0 occurrences of `:8000`.

Not performed: no PostgreSQL migration was run (no PostgreSQL instance is available); no live SMTP delivery test; no load test; no backup/restore drill; no `pip-audit` or `npm audit`; no GitHub Actions run observed; no infrastructure provisioned and nothing deployed.

---

12. Reconciliation with existing documentation

Reviewed: `docs/audits/PRODUCTION_OPERATIONS_CHECKLIST.md`, `docs/audits/EMAIL_VERIFICATION_SETUP.md`, the workspace `haryana/docs/audits/NEP_PRODUCTION_GO_LIVE_CHECKLIST.md`, `NEP_PRODUCTION_SECURITY_FINDINGS.md` and `NEP_PRODUCTION_REMEDIATION_RESULTS.md`. Those documents were **not edited**. Discrepancies found:

Document	Statement	Code reality
EMAIL_VERIFICATION_SETUP §1, §2.1, §3.1	Links are built from `FRONTEND_BASE_URL`	The code reads `FRONTEND_URL` (`base.py:50`, `email_verification_service.py:117`, `activation_service.py:85`, `password_reset.py:21`). `FRONTEND_BASE_URL` has no effect.
PRODUCTION_OPERATIONS_CHECKLIST §2.1	Lockout uses `django-axes`	django-axes is not installed; lockout is custom and cache-based (`authentication/views.py`)
PRODUCTION_OPERATIONS_CHECKLIST §2.1	Redis "mandatory" for production	Correct in principle, but not enforced by `production.py`, and the `redis` package is missing (G3)
PRODUCTION_OPERATIONS_CHECKLIST §4.2	Audit logs are in `apps.audit.models.AuditLog`	There is no `apps.audit` app
PRODUCTION_OPERATIONS_CHECKLIST §3.3	Restore check queries `institutions_institution` and `assessments_assessment`	There are no `institutions` or `assessments` apps; the row-count queries must be rewritten against real table names
PRODUCTION_OPERATIONS_CHECKLIST §5	Test counts 862 backend / 102 frontend; status "Ready for Production Provisioning"	Current counts are 877 / 109. G1–G8 are open, and the remediation results report still says NOT READY.
PRODUCTION_OPERATIONS_CHECKLIST §1.2	`migrate --settings=config.settings.production`	Correct. Note that a bare `manage.py` defaults to **development** settings.
GO_LIVE_CHECKLIST A6 / table row "SMS gateway"	An SMS provider is a go-live requirement	Signup has moved to email verification and the frontend no longer calls OTP; confirm with HSHEC (Q6)
GO_LIVE_CHECKLIST, ops intro	Hosting is Azure App Service	The workflow targets Azure, but nothing has been deployed there. The requested VMs will be the first hosting environment (§8).